Clean Your Room: Messy Networks & The Data Centers That Hate Them.

trimarcsecurity.com/hub-post/clean-your-room-messy-networks-the-data-centers-that-hate-them

Sean Burgess July 31, 2023

Updated: Dec 13, 2024

Messy networks are like messy bedrooms. It's hard to find anything you want, and you often find something you don't want at exactly the worst time. Imagine finding a snake in your bedroom. Would you rather find it slithering across the floor in the open or when you pick up a t-shirt that's been piled in your "floordrobe"?

It's much easier to find a snake in your bedroom when the room is clean, and the same goes for your network. The more organized an environment, the easier it is to find abnormalities and persistence created by attackers. This article explores some of the messy practices that lead to insecure networks. This blog is primarily focused on Active Directory (AD) but will address many concepts that are universal in system and network administration.

Naming Conventions

Bad Naming Conventions are a matter of opinion, but a naming convention should follow a few fundamental concepts to be considered good. All names should be clear and easy to understand. Usernames should allow you to easily tell if the account is an admin, service, or user account. Hostnames should clearly indicate whether the device is a server, workstation, printer, etc. You want your Admins and security analysts to know what they are looking at quickly.

In many networks, there are no standards for account names indicating what type of account they are. There should be a clear and understandable naming convention for all accounts but especially administrator accounts.

Naming conventions to avoid:

- Only Initials: Account names that are created solely from the user's initials. This requires that admins remember everyone's initials at first glance. It also makes it easier to mistake service accounts with users or even poorly named admin accounts. "Is the VM account the service account for vSphere or is it Vanshi Maadiga's user account?"

- Random Characters: Account names that look like they were generated by an encryption algorithm. Random account names may feel secure, after all, who is going to know what these accounts are? – but security through obscurity just makes it harder for your admins to manage privileged accounts.
- Themed Names: Names derived from a specific theme (fantasy, sci-fi, science, literature, etc.) Your admins might have fun naming all the servers after their favorite cartoon characters but eventually you will have new admins. They won't know what anything does unless your documentation is immaculate. Even if everyone on your immediate team understands what each server does, these naming conventions will slow down auditors, assessors, and incident responders. "Does anyone know what the Zeus server does?"

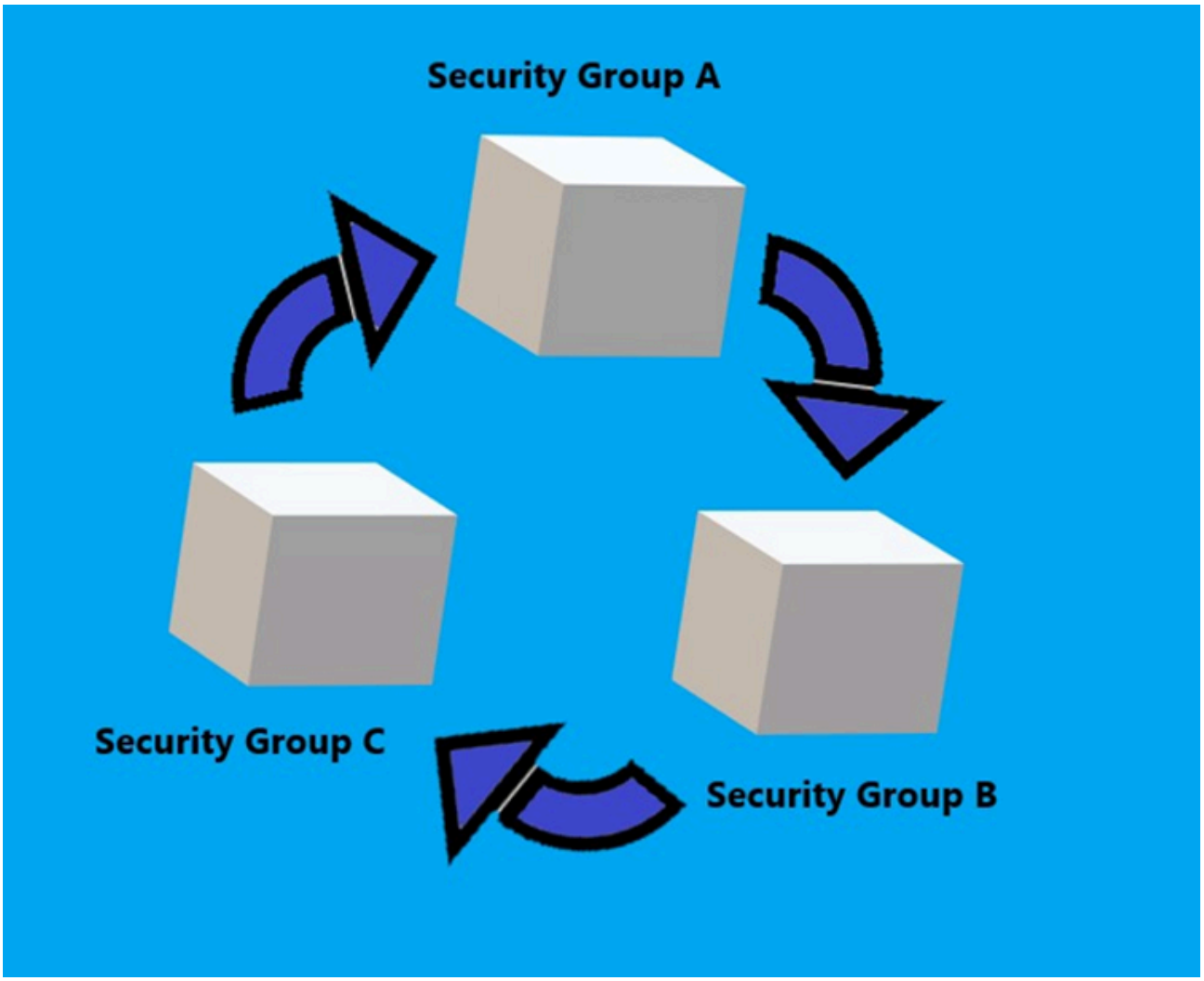


Security Groups

Security Groups are a basic organizational tool to manage privileges and permissions for multiple users, service accounts, or devices. They are a powerful tool to control who has access to assets without having to work with individual user accounts. Unfortunately, with great power comes great responsibility, and a few bad habits can turn Security Groups into a weakness.

Security Group Habits to Avoid:

- **Nested Security Groups:** Any security group which is a member of another security group. Nested security groups are an issue because it's hard to quickly identify who has elevated privileges. For example, if a user is a member of a security group nested three groups below the Administrators group, it's very difficult to see why the user is allowed to do administrative tasks. This leads to accidental privilege elevation and makes it harder to see if a malicious actor has gained elevated privileges.
- **Circular Nesting**: A special type of nesting in which one group has another group as both a parent and a child. When this happens, every group in the circle inherits the full privileges and permissions of every other group in the circle. That is, Group A is a member of Group B which is a member of Group C which is a member of Group A which is a member of Group B which is a member of Group C… you get the point. In this configuration, granting permissions to any one of these groups grants the same set of permissions to all three groups.



Multi-purpose Security Groups: Security groups with a large scope of functionality. Security groups should be tightly focused and provide the least permissions required to complete a specific task. When your network is small and only contains a few admins, it doesn't seem like a problem to have one security group that manages Local Administrators Password Solution (LAPS), Group Policy Objects (GPOs), AD, AD Certificate Services (AD CS), print services, SQL, and third-party services. But as an organization scales up, these roles will likely be performed by distinct groups of users.

If all your admins are members of a group called "Admins" regardless of what they are actually administering, you will end up with users with excessive permissions. There is no reason for the security group that manages application SQL databases to have broad Domain Admin (DA) privileges. Security groups should have a limited scope of use and be named in a way to clearly indicate what they are used for.



Orphaned Objects

Orphaned Secure Identifiers (SIDs) are often left in privileged group membership, on custom domain permissions, in AD User Rights assignments, and other ACLs in Active Directory. These present two risks.

1. **Account Recovery:** Orphaned SIDs can be recovered from AD-aware backup systems. This means that an account that was deleted at some point can be recovered and will maintain any lingering permissions associated with its original SID.

2. **Synthetic SID Injection Attack:** This attack allows attackers to effectively guess existing SIDs and artificially duplicate the SID on a new account. This subsequently grants the new account whatever permissions the existing SID has.

Orphaned Objects should be removed wherever they are found.



Old and Never Expiring Passwords

This item is often considered low hanging fruit, yet nearly every environment has at least a few admin, service, or user accounts with passwords that never expire. The longer a static password remains in use, the greater the chances it will be discovered or cracked.

The biggest culprit is usually service accounts. Service accounts are often used in third-party services and applications and have passwords that can't be easily updated. Many administrators view this task as both a hassle and a risk to operations and avoid changing service account passwords unless absolutely necessary.

Instead of dreading service account password changes, administrators should consider regular password changes an opportunity to ensure that production services have adequate support and confirmed service owners. It's less stressful to resolve potential problems with a service as part of planned maintenance when it's still working instead of the first time something goes wrong.

Here are some tools to find users with passwords that never expire in Active Directory:

For single domains:

For multiple domain forests:



Legacy Software & Drivers

Old software and drivers are security incidents waiting to happen. Applications and drivers fall out of support, and eventually someone finds an attack vector that can be exploited. Old software and out-of-date drivers should be removed whenever possible. This is especially the case on critical systems like Domain Controllers.

The easiest way to resolve this problem is to have regular replacement cycles for production servers. Don't just upgrade existing servers in-place. When it's time to move to the next Operating System or primary software version, build new servers and migrate the required services. This incidentally allows for smooth migrations into the latest and greatest OS and applications.

Additionally, software on critical systems like Domain Controllers should be reviewed annually. It's easy to forget to update or remove a tool that is no longer actively in use. But don't worry, on a long enough timeline, someone will find that forgotten piece of software. Make that someone be an employee of your company and not a "bonus administrator" working for a ransomware gang.



Legacy Operating Systems

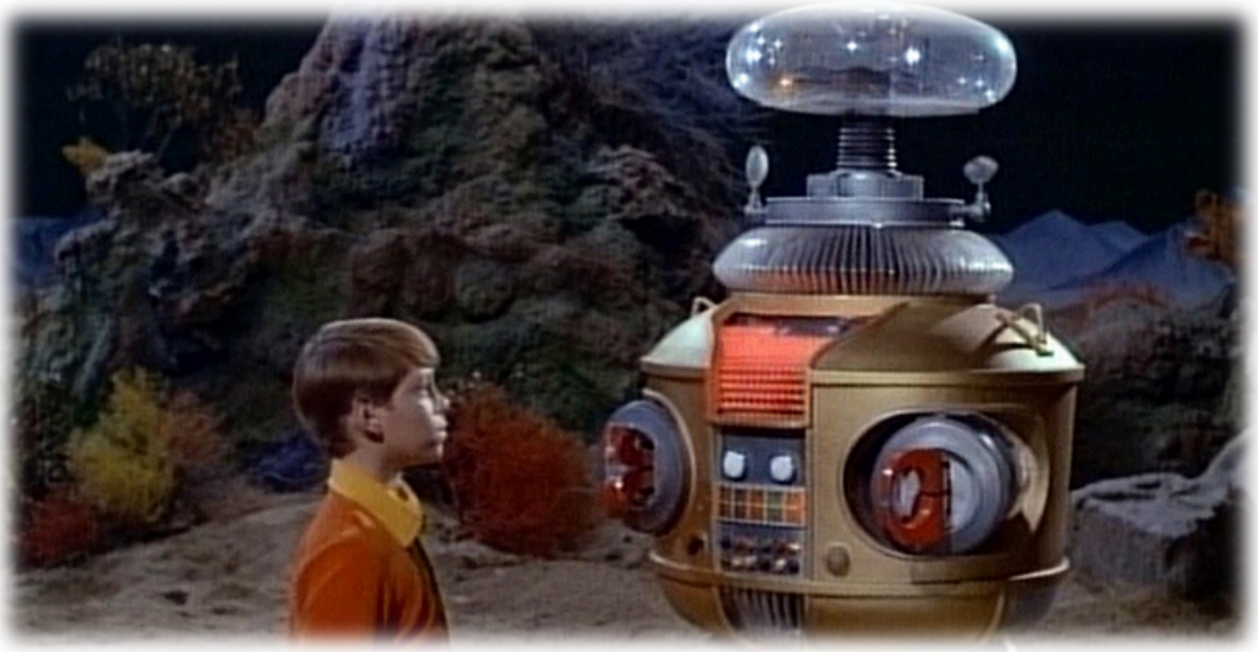
This is another piece of low hanging fruit that is regularly missed. Nearly every environment I have administered or assessed has had Operating Systems that are out of support or nearing the end of life. Legacy Operating Systems are far more likely to have unaddressed vulnerabilities. They are also typically unable to run modern tools or enable newer features that can significantly improve the security of the network. As a side benefit, newer tools and features often improve the quality of life of the administrators and security teams that manage your network.



Legacy Servers

This seems like a no brainier, but why are you keeping servers alive that no longer serve a function? These legacy servers are vulnerabilities waiting to be exploited, and they are made more vulnerable due to the fact that no one cares about them. There is a high risk that no one will be cleaning up legacy permissions or improving monitoring on out of production systems. Because no one is monitoring these systems, they make great jump servers for attackers.

Let’s make this clear: there is no reason to have a BlackBerry Enterprise Server in 2023. Yes, Trimarc has seen this installed on Domain Controllers.



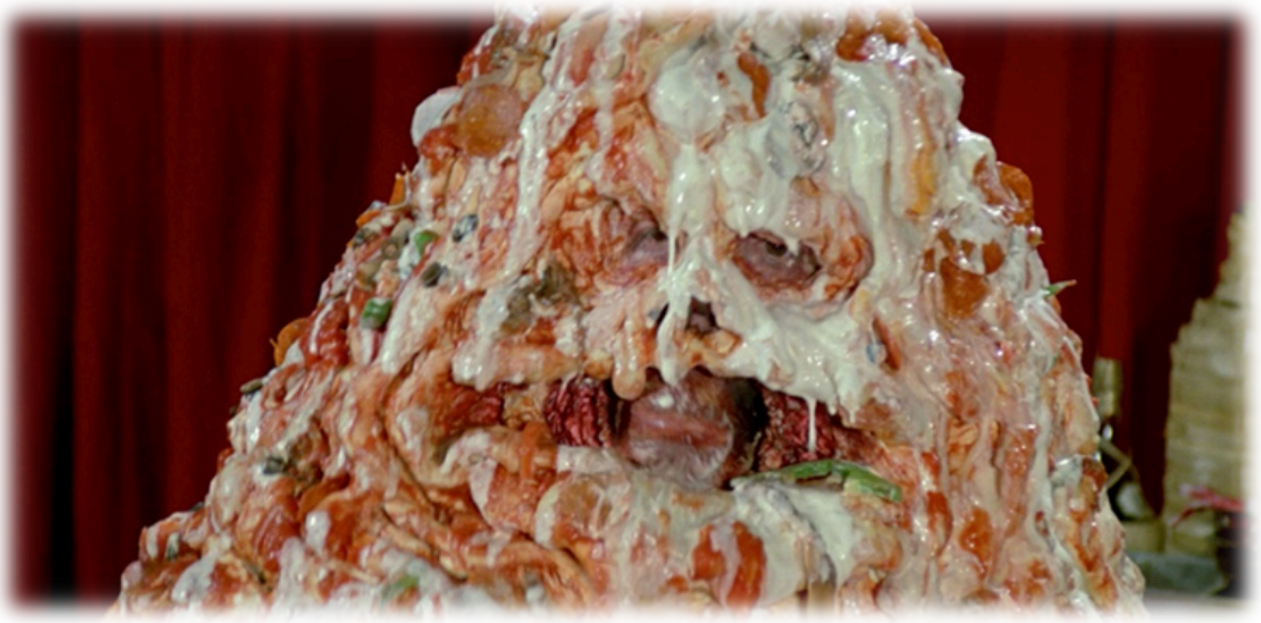
Sloppy File Management

This topic could be its own article and in fact, it is. You can read more about better file management for dealing with ransomware in Don't Pay the Reaper: File Share Security Against Ransomware. Your files are often the most valuable assets contained in the network and yet they are often managed with little to no forethought. There are a number of questions that should be answered before any file management system is implemented.

- "How many physical sites will my files need to be accessed from?" The answer to this question will guide whether you want your files to be on a single file server, DFS shares across multiple sites, or in the cloud.
- "How much data am I looking to store?" You want to make sure you have enough space and room to grow to accommodate your file storage. This means disk space on your servers and in your virtual infrastructure. This also means making sure that you aren't still using MBR partitions instead of GPT which supports larger disk sizes. Disk partition is becoming less of a consideration as everything naturally migrates to GPT.
- "Who is going to need to access my files?" You should be building your file storage with security groups and permissions in mind.
- "How are my files going to be backed up?" Keep your data segregated through datastore, volume, and security groups in a way that allows for the smallest unit of recovery in the case of an emergency. The less you have to restore, the faster the recovery will be and the less chance of data loss there is.

Don't be the network with one giant storage volume and broad security access. This is a major vulnerability and opens your network up to Ransomware, DDoS, internal espionage,

and general data loss due to unforeseen disasters.



Dirty DNS

The first step to defending your DNS architecture is understanding it. It's hard to understand your DNS when you have static A records from 20 years ago still sitting there like a piece of Lego on your floor. Clean up the following items to make DNS administration and security a lot easier.

- **Static Records:** Switch your DNS records to dynamic and most of the cleanup is done for you. Static records should only be used when absolutely necessary.
- **Orphaned Zones:** Over time you will see IP ranges or domain FQDNs come and go. Make sure to remove their corresponding DNS zones when they are no longer in use.
- **Stale Records:** Getting rid of static records where possible will drastically reduce the number of stale records you encounter but not all of them. Periodically remove records belonging to websites, servers, workstations, and devices that no longer exist in your network. DNS Scavenging is a powerful tool for cleaning up stale records but should be used cautiously because it can potentially remove static records that don't change very often but are still needed.

- **Legacy Subdomain Records:** An external DNS record is automatically created when a new external subdomain is created. This record is not automatically deleted when the subdomain is removed or is no longer in use. This record should always be manually removed when its corresponding subdomain is removed for any reason. Failure to do this can lead to Subdomain Hijacking. This is a process where an attacker uses shared access to a common host like Amazon AWS to subvert a legacy DNS record for a deleted subdomain to point to a page of the attacker's choosing. This can lead to reputational damage if your subdomain links to malicious sites or even just unintentional adware.



DHCP Scoping

DHCP scopes are often quickly set up then quickly forgotten and only to receive attention when you start running out of addresses. Instead, take the first step to mitigate potential DoS attacks and annually assess your DHCP scopes. Ensure they are large enough to accommodate your current needs with room to grow. That wiggle room is what gives you time to react if and when you find your DHCP flooded with malicious requests.

Also remember to remove unneeded IP reservations for devices that are no longer in use. Typically, it's easier to avoid making reservations in the first place by simply having IP address ranges outside of any DHCP scope that can be statically granted for those few devices or sites that require them. The best way to avoid DHCP scopes overlapping with required static addresses is to have subnets pre-designated for specific uses like servers, internal websites, etc.



Trusts

Trusts are sometimes necessary but can easily turn into a security liability. The most concerning trusts are External Trusts. These trusts can allow external users to access and potentially administer your Forest. Congratulations! Many of the vulnerabilities in these externally trusted forests are now vulnerabilities in your forest too. Because of this, inactive trusts should be removed whenever possible.

External trusts that must remain should be considered an extension of your forest's security boundary and should be managed as such.

Trusts also introduce the concept of cross-forest administration. This is when users in Forest A perform administrative tasks in Forest B. While there are ways to perform cross-forest administration securely, it's rarely managed properly. Remove any unnecessary cross-forest administration to reduce the risk of unwanted privilege escalation.



Documentation

Documentation is necessary for any functional network. Good docs maintain institutional knowledge, and keep administrators on the same page on any project. Documentation should lay out the plan and reasoning behind your overall network architecture. Unfortunately, documentation is not immune from the messy habits that can degrade the manageability and general security posture of your network.

- **Missing Documentation:** Failing to document network changes is the most common problem for most organizations. This can be avoided through documentation management tools.
- **Legacy Documentation:** It’s almost as important to remove legacy items from your documentation as it is to document new items in the first place. Legacy documentation leads to confusion, mismanagement, and slow response times. If older documentation cannot be removed for legal or regulatory reasons, it should be clearly labeled or archived to minimize confusion.



OU Structure

The first step in keeping your Organizational Units (OUs) manageable is having a plan. Before you start building out your OU structure, you should know the answers to the following questions:

- What security groups am I going to have?
- What are these security groups going to be used for?
- What level of permissions should be associated with my various users and groups?
- Do I have multiple sites, departments, or other management concerns when it comes time to logically divide my forest objects?

If you have already built your forest and are just trying to clean it up, you can still use these ideas as a guide.

The second step in keeping your Organizational Units (OUs) manageable is the KISS (Keep It Simple Silly) rule. Don’t overcomplicate your OU layout. Use the following tips to keep your OU layout from getting out of control.

- Have a consistent and understandable naming convention for all OUs.
- Make sure your OU naming convention is consistent with the naming convention for all of your objects (see above).
- Don’t nest OUs more than necessary.

- Clearly identify who is authorized to manage your OU infrastructure.
- Once your desired OU layout is complete, make sure all top-level OUs have "Protect from Accidental Deletion" marked.
- If you have to block GPO inheritance on an OU, that probably means your structure is wrong.



Permissions

Messy permissions in an Active Directory forest are one of the biggest paths towards unwanted privilege escalation. Cleaning up forest permissions requires a comprehensive use of the concepts previously discussed in this article.

- Custom groups should be created with specific functions in mind and only be granted the minimum rights required to perform those functions.
- Custom groups with elevated permissions should only contain clearly named elevated accounts as members.
- Rights granted on top-level OUs and the domain root should be extremely limited and frequently scrutinized.
- Custom permissions should never be allocated to individual user accounts. Use security groups to manage permissions.

- Review custom permissions annually.
- Review custom security group membership monthly.
- When reviewing the permissions in your forest, check the following
- Domain Controller User Rights Assignment
- Domain Controller Share Permissions
- Privileged Object Security Permissions
- Privileged OU Security Permissions
- Group Policy Permissions
- Exchange Permissions



Alerting

As mentioned before, the biggest reason for cleaning up your network is to make it easy for Admins and security analysts to quickly understand what is going on in the network. To really get a handle on your network, you'll need a SIEM to consolidate event logs and alerting. Here are a few notes for configuring your auditing and alerting:

- Make sure the SIEM is gathering at least the Security logs from all workstations, servers, and domain controllers.
- Enabled advanced auditing and make sure to follow Microsoft's recommendations here.
- Ensure that alerting is configured for actions like adding users to privileged security groups.
- Enumeration of privileged groups should be captured.

The principles listed above are focused on Active Directory but apply to other systems like VMware, Azure, and networking equipment. Ultimately the cleaner your network is, the easier monitoring and incident response will be.



Conclusion

The first step to keeping your environment secure is to keep it clean. You can't secure what you don't fully understand or fully see. Security starts with operational excellence.

We reviewed the following places where bad habits and messy practices can lead to serious vulnerabilities:

- Naming Conventions
- Security Groups

- Orphaned Objects
- Old or Never Expiring Passwords
- Legacy Software & Drivers
- Legacy Operating Systems
- Legacy Servers
- Sloppy File Management
- Dirty DNS
- DHCP Scoping
- Trusts
- Documentation
- OU Structure
- Permissions
- Alerting

If you've read this far, it means that you care about keeping your network secure. Take the concepts reviewed here to make your administration and security teams' lives easier.



So, you like reading about Active Directory? Well, you're gonna love our upcoming webinar!

Even The Great Wall Ends At The Sea: Pitfalls Of Ever Expanding Security Boundaries. Register here: https://attendee.gotowebinar.com/register/7806576969952209503

About Trimarc Security:

Trimarc is a professional services company based out of Washington, DC specializing in ***Active Directory, Entra ID, and VMWare vSphere*** *assessments. We specialize in helping organizations secure their Microsoft platform, both on-premises and in the cloud. Founded by Sean Metcalf, a Microsoft Certified Master in Active Directory, Trimarc's mission is to help organizations better secure their critical IT infrastructure.*